

01

Security Copilot: el modelo de acceso en dos niveles

Dar acceso a Security Copilot y dar acceso a los datos subyacentes son cuestiones diferentes.

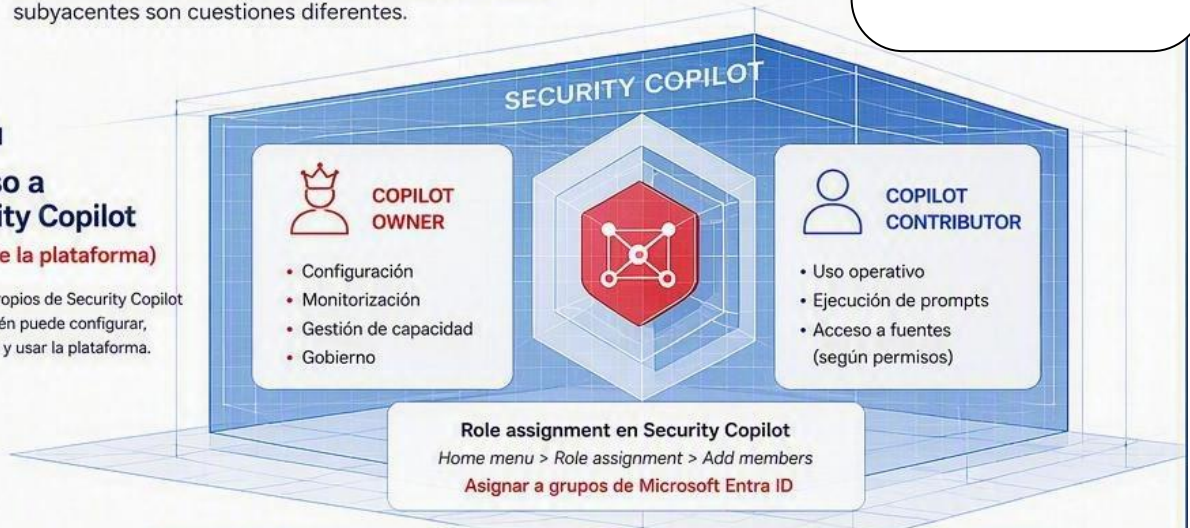
1

NIVEL 1

Acceso a Security Copilot

(RBAC de la plataforma)

Los roles propios de Security Copilot definen quién puede configurar, administrar y usar la plataforma.



PRÁCTICA RECOMENDADA

Usar grupos de seguridad en Microsoft Entra ID.
Evitar asignar "Everyone" o usar solo "Security Administrator".

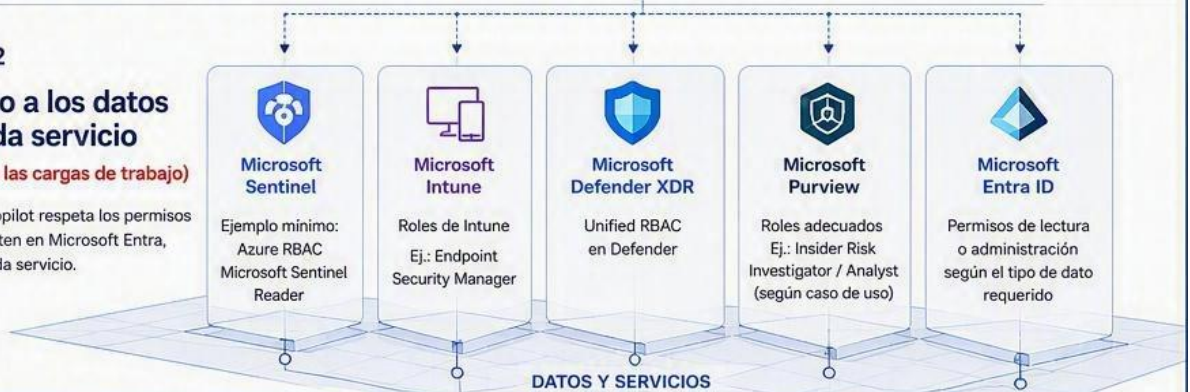
2

NIVEL 2

Acceso a los datos de cada servicio

(RBAC en las cargas de trabajo)

Security Copilot respeta los permisos que ya existen en Microsoft Entra, Azure y cada servicio.



PRINCIPIO TRANSVERSAL

Security Copilot accede "on-behalf-of" del usuario autenticado y respeta los roles y permisos existentes en cada servicio.



3

DISTINCIÓN DE ALCANCE



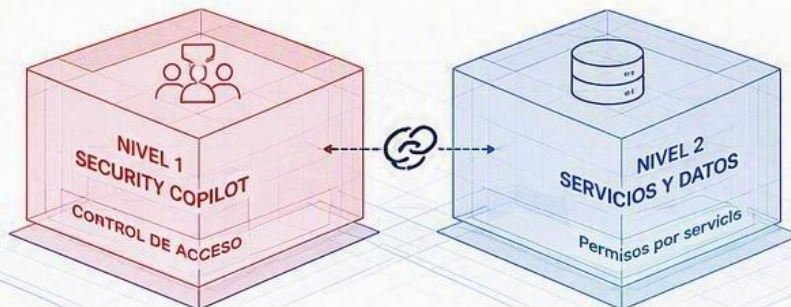
Rol de Copilot

Define capacidades dentro de la plataforma de Security Copilot.



Permiso sobre el servicio / dato

Define qué información puede ser leída o administrada desde cada carga de trabajo.



REFERENCIAS CLAVE

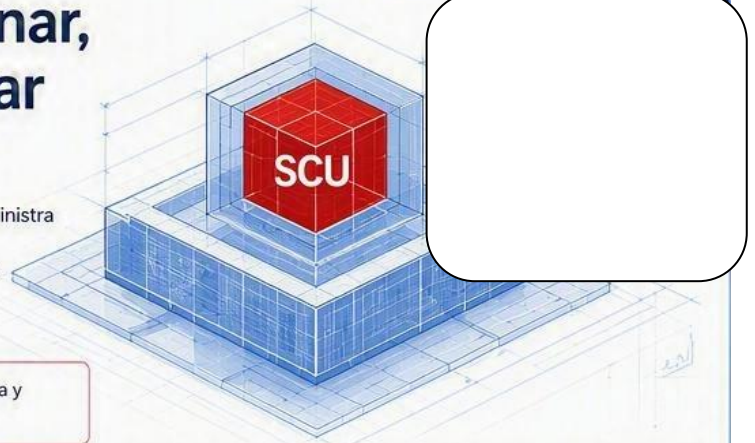
- Asignación de roles de Security Copilot: learn.microsoft.com/copilot/security/authentication#assign-roles
- Autenticación y acceso a plugins: learn.microsoft.com/copilot/security/authentication
- RBAC en Microsoft Sentinel: learn.microsoft.com/azure/sentinel/roles
- RBAC en Intune: learn.microsoft.com/mem/intune/fundamentals/role-based-access-control
- RBAC en Microsoft Defender: learn.microsoft.com/microsoft-365/security/defender/manage-rbac



02

SCUs: dimensionar, controlar y ajustar la capacidad

La capacidad de Microsoft Security Copilot se administra mediante Security Compute Units (SCUs). Observe el consumo, anticipe necesidades y ajuste la capacidad según el uso real.



SCU (Security Compute Unit): unidad de cómputo que habilita y sustenta el procesamiento de Microsoft Security Copilot.

1 OBSERVAR: USO Y LÍMITES

Portal: securitycopilot.microsoft.com
Ruta: Home menu > Owner settings > Usage monitoring



Qué puede ver

- Unidades aprovisionadas y overage
- Plugins utilizados
- Iniciadores (quién consume)
- Filtros por período, plugin, iniciador y más
- Exportación de datos
- Historial de 90 días

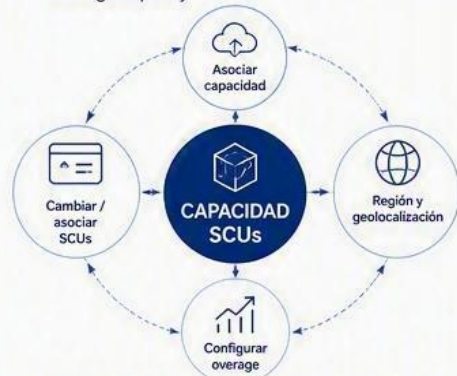


NOTIFICACIONES DE LÍMITE

Al acercarse al límite de SCUs, Copilot notifica al enviar prompts. (Ejemplo: Defender for Cloud)

2 GESTIONAR: CAPACIDAD (SCUs)

Portal: securitycopilot.microsoft.com
Ruta: Home menu > Owner settings > Manage capacity



REQUISITO DE PERMISOS

Para comprar, cambiar o asociar SCUs, se requiere ser Azure Owner o Contributor sobre el recurso de capacidad en Azure.

3 PLANIFICAR: DIMENSIONAMIENTO DE SCUs



Estime sus necesidades de SCUs antes de aprovisionar.
Use el estimador de costos y capacidad de Security Copilot:

securitycopilot.microsoft.com/calculator



PLANEACIÓN

- ☒ Proyección de consumo
- ☒ Cobertura de casos de uso
- ☒ Dimensionamiento recomendado

4 CONTEXTO: TENANT M365 E5 (10.000 USUARIOS)

La cobertura de Security Copilot depende de la capacidad SCU asociada.

Planifique, monitoree el consumo real y ajuste cuando sea necesario.



ENFOQUE RECOMENDADO

- ✓ Estimar SCUs con el calculador
- ✓ Monitorear uso y límites
- ✓ Ajustar capacidad u optimizar prácticas de uso
- ✓ Gobernanza mediante grupos Microsoft Entra



REFERENCIAS CLAVE

- Manage SCU usage and limits: learn.microsoft.com/copilot/security/manage-usage
- Owner settings y capacidad (SCU association/overage): learn.microsoft.com/copilot/security/owner-settings
- Estimador de Security Copilot: securitycopilot.microsoft.com/calculator
- Qué es Security Copilot: learn.microsoft.com/copilot/security/microsoft-security-copilot



Sources y plugins: conectar Security Copilot con el ecosistema de seguridad

Security Copilot obtiene valor cuando se conecta de forma controlada a las fuentes de datos y plugins del ecosistema.

La calidad, cobertura y gobierno de estas conexiones determinan la calidad de las respuestas y recomendaciones.

SOURCES

Dónde obtiene información

-  Datos nativos de Microsoft Security
-  Datos de Microsoft 365
-  Registros e infraestructura (on-prem y cloud)
-  Fuentes de terceros
-  APIs y conectores personalizados

PLUGINS

Qué capacidades extienden

-  Análisis avanzado y hunting
-  Enriquecimiento de amenazas
-  Gestión y remediación automatizada
-  Soporte y conocimiento especializado
-  Integraciones ISV
-  Workflows personalizados

SECURITY COPILOT

Comprende, razona y actúa con contexto empresarial

Identidad y acceso

GOBERNANZA Y CONTROL

Confianza, privacidad y cumplimiento

Políticas y cumplimiento

CÓMO FUNCIONA LA CONEXIÓN

1 DESCUBRIR

Identificar fuentes y plugins disponibles, su alcance y propósito.



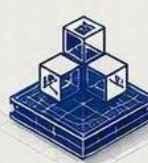
2 CONECTAR

Configurar conectores y autenticación segura hacia cada origen.



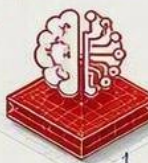
3 NORMALIZAR

Unificar y estructurar datos para comprensión consistente.



4 UTILIZAR

Security Copilot consulta, analiza y genera resultados.



EJEMPLOS (NO EXHAUSTIVO)

Fuentes

- Microsoft Defender XDR
- Microsoft 365 (Purview, Entra, Intune, Exchange, SharePoint)
- Microsoft Sentinel / Log Analytics
- Azure (Activity Logs, Resource Graph)
- TI on-prem (SIEM, firewalls, proxies)
- Fuentes externas (Threat Intel, ISACs)
- APIs y conectores personalizados

Plugins

- Análisis forense avanzado
- Enriquecimiento de amenazas
- Automatización y remediación
- Generación de reportes
- Gestión de casos y tickets
- Workflows y acciones personalizadas

BUENAS PRÁCTICAS



Conexiones mínimas necesarias

Conectar solo lo requerido para el caso de uso.



Principio de menor privilegio

Accesos y roles limitados por función y alcance.



Calidad de datos

Validar disponibilidad, integridad y frescura de los datos.



Monitoreo continuo

Supervisar conectores, errores, latencia y cobertura.



Revisión y mejora periódica

Actualizar fuentes, plugins y políticas de uso.



Las fuentes y plugins adecuados, conectados con gobernanza, convierten **contexto en decisiones y acciones efectivas.**

De los datos al caso de uso: Promptbooks, capacidades y plugins

Security Copilot transforma datos y señales en decisiones y acciones mediante promptbooks reutilizables, capacidades nativas y plugins del ecosistema.

1 DATOS Y SEÑALES

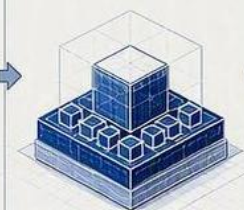
Se ingieren datos y señales de múltiples fuentes.



- Telemetría de seguridad
- Identidades y accesos
- Configuraciones y postura
- Alertas e incidentes
- Datos de negocio relevantes

2 NORMALIZACIÓN Y ENRIQUECIMIENTO

Se estructuran los datos y se agrega contexto.



- Normalización y correlación
- Enriquecimiento de contexto
- Clasificación y etiquetado
- Relaciones y dependencias
- Reducción de ruido

3 PROMPTBOOKS (MEJORES PRÁCTICAS)

Estandarizan cómo preguntar, analizar y actuar.



- Prompts reutilizables
- Flujos de análisis guiados
- Instrucciones y contexto
- Plantillas por escenario
- Resultados esperados

4 CAPACIDADES NATIVAS

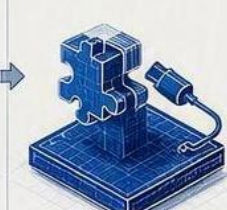
Aportan análisis avanzado, automatización y ejecución.



- Análisis e investigación
- Resumen y explicación
- Detección y priorización
- Automatización y orquestación
- Generación de reportes

5 PLUGINS (ECOSISTEMA)

Extienden el alcance con herramientas y servicios.



- Conectores y plugins
- Integraciones ISV
- APIs y servicios externos
- Herramientas especializadas
- Contexto adicional

Retroalimentación para mejorar prompts, conectores y capacidades

QUITAR COMPLEJIDAD. MAXIMIZAR VALOR.



PROMPTBOOKS

Estandarizan el conocimiento para que cualquier analista obtenga resultados consistentes y repetibles.

Incluyen:

- Objetivo del escenario
- Contexto requerido
- Prompts paso a paso
- Fuentes y plugins utilizados
- Salidas y criterios de éxito

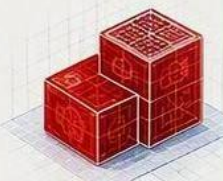


CAPACIDADES NATIVAS

Son las habilidades incorporadas en Security Copilot que permiten entender, razonar y actuar.

Ejemplos:

- Investigación y triage asistido
- Resúmenes ejecutivos
- Explicación de alertas
- Búsqueda y correlación
- Automatización de tareas
- Generación de dashboards

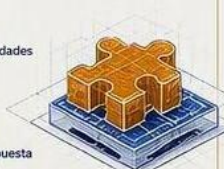


PLUGINS

Extienden el alcance con soluciones especializadas y fuentes externas.

Ejemplos:

- Análisis forense
- Gestión de vulnerabilidades
- Threat Intelligence
- Gestión de tickets
- Orquestación SOAR
- Herramientas de respuesta



CÓMO SE CONVIERTE EN UN CASO DE USO

1 DEFINIR EL ESCENARIO



Objetivo claro y valor esperado.

2 IDENTIFICAR DATOS Y FUENTES



Qué datos se necesitan y dónde están.

3 SELECCIONAR PROMPTBOOK



Usar o adaptar el promptbook del escenario.

4 CONSIDERAR CAPACIDADES



Definir qué capacidades nativas aportan valor.

5 ELEGIR PLUGINS NECESARIOS



Agregar plugins que extiendan el análisis.

6 OBTENER RESULTADOS Y ACTUAR



Generar insights y ejecutar acciones.

VALOR ENTREGADO



MEJOR CALIDAD DE RESPUESTAS

Datos relevantes, contexto completo y análisis consistente.



MAYOR VELOCIDAD DE ANÁLISIS

Menos tiempo manual, más automatización inteligente.



DECISIONES CONFIABLES Y TRAZABLES

Razonamiento claro, evidencias y acciones documentadas.



ESCALABILIDAD DEL CONOCIMIENTO

Promptbooks reutilizables, capacidades y plugins compartidos.



MEJORA CONTINUA

Aprendizaje de cada caso, retroalimentación y ajuste permanente.



La combinación de datos de calidad, promptbooks, capacidades nativas y plugins convierte señales en **decisiones y acciones efectivas**.

Standalone: habilitación y validación de extremo a extremo

Un despliegue standalone permite habilitar Microsoft 365 Copilot y agentes sin integración inicial con sistemas externos, validando de extremo a extremo seguridad, gobierno, protección de datos y operación.

PRINCIPIOS DEL MODELO STANDALONE



CONTROLADO

Habilitación gradual con controles y guardrails definidos.



SEGURA

Identidad, acceso y protección de datos como prerequisites obligatorios.



OBSERVABLE

Monitoreo y trazabilidad desde el primer día de operación.



VALIDABLE

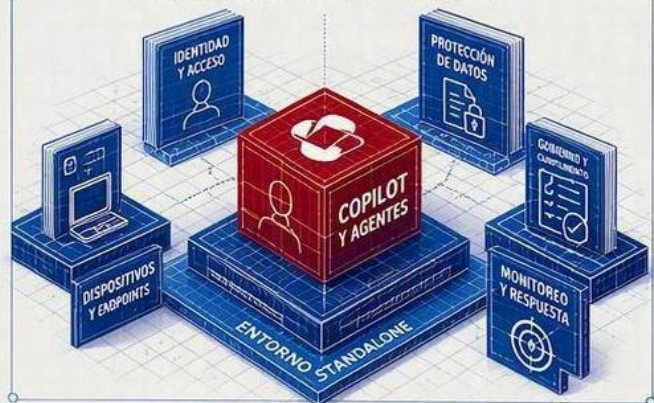
Criterios claros de aceptación y evidencias de cumplimiento.



REPRODUCIBLE

Modelo simple y documentado para escalar a otras cuentas.

ENTORNO STANDALONE (REFERENCIAL)



PROCESO DE HABILITACIÓN Y VALIDACIÓN END-TO-END

1

DEFINIR ALCANCE Y OBJETIVOS



- Casos de uso iniciales
- Usuarios y grupos piloto
- Dominios y datos incluidos

2

PREPARAR EL ENTORNO



- Identidad y acceso
- Dispositivos
- Red y conectividad
- Licenciamiento

3

CONFIGURACIÓN ÓPTIMA



- Políticas y guardrails
- Protección de datos
- Retención y auditoría
- Permisos y roles

4

HABILITAR COPILOT Y AGENTES



- Activación controlada
- Configuración inicial
- Agentes y permisos específicos

5

VALIDAR SEGURIDAD Y CUMPLIMIENTO



- Pruebas de seguridad
- Clasificación y DLP
- Auditoría y registros
- Cumplimiento

6

VALIDAR CASOS DE USO



- Pruebas funcionales
- Calidad de las respuestas
- Límites y excepciones
- Retroalimentación

7

DOCUMENTAR Y CERRAR CICLO



- Evidencias y reportes
- Lecciones aprendidas
- Decisión de escalado
- Plan de mejora

QUÉ VALIDAR DE EXTREMO A EXTREMO

Seguridad	¿El entorno cumple con los controles y políticas definidos?
Protección de datos	¿Los datos están clasificados, protegidos y con DLP activo?
Acceso y permisos	¿Solo los usuarios y agentes autorizados tienen acceso a los recursos?
Auditoría y trazabilidad	¿Todas las acciones críticas están registradas y disponibles?
Casos de uso	¿Los resultados cumplen expectativas y requieren ajustes?
Operación y monitoreo	¿Existen alertas, reportes y métricas clave activas?
Criterios de aceptación	¿Se cumplieron los criterios definidos para pasar a expansión?

CRITERIOS DE ÉXITO STANDALONE

Controles de seguridad activos y efectivos	Datos protegidos y solo accesibles por autorizados	Visibilidad completa de uso y actividades	Casos de uso validados con resultados confiables	Usuarios satisfechos y adopción inicial lograda	Evidencias y documentación completas y auditables
--	--	---	--	---	---

MÉTRICAS INICIALES RECOMENDADAS

Adopción (usuarios activos)	Uso de casos de uso clave	Incidentes o alertas relevantes	Tiempo de respuesta y resolución	Cumplimiento de políticas y guardrails	Calidad de respuestas y precisión
-----------------------------	---------------------------	---------------------------------	----------------------------------	--	-----------------------------------

RIESGOS A GESTIONAR

- ⚠ Exposición de información sensible.
- ⚠ Permisos excesivos o mal configurados.
- ⚠ Resultados inexactos o alucinaciones.
- ⚠ Brechas de monitoreo y auditoría.
- ⚠ Falta de documentación y trazabilidad.

DEL PILOTO STANDALONE A LA ESCALABILIDAD

Una validación exitosa establece la base para integrar fuentes externas, ampliar casos de uso y escalar con confianza.



PRÓXIMOS PASOS

- ✓ Revisar resultados con stakeholders.
- ✓ Ajustar políticas y capacidades.
- ✓ Definir plan de expansión.
- ✓ Evaluar integración de fuentes y plugins.
- ✓ Replicar en nuevas cuentas.



El modelo standalone **reduce riesgos, valida capacidades** y garantiza una **base sólida para expandir** Microsoft 365 Copilot y agentes.

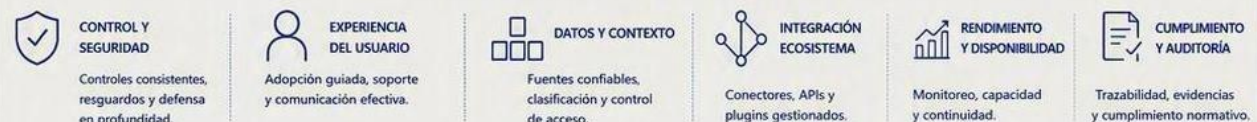
Operar Security Copilot a escala: gobierno, monitoreo y extensión

La operación a escala requiere gobierno claro, monitoreo continuo, gestión de capacidades y un ecosistema de plugins y extensiones que evoluciona de forma controlada.

MODELO OPERATIVO DE SECURITY COPILOT



CAPACIDADES CLAVE DE LA OPERACIÓN A ESCALA



CICLO CONTINUO DE OPERACIÓN



GOBIERNO DE PLUGINS Y EXTENSIONES



ROADMAP DE MADUREZ (REFERENCIAL)



La operación a escala solo es sostenible con **gobierno, monitoreo** continuo y un ecosistema de plugins y datos confiable.